

APPENDIX - PROMPT TEMPLATES

A. Vulnerability Type

```
The following vulnerability types (keys) with
corresponding descriptions (values) exist:
{ 'Deserialization of Untrusted Data': <CWE-DESCRIPTION>,
  <...>
}
Given a new CVE with description:
<CVE-DESCRIPTION>
Which vulnerability type does this CVE map to? Provide
only the vulnerability type. If no vulnerability type
applies, answer with 'N/A'
```

B. Functionality

This prompt is repeated for each of the 14 functionalities:

```
Determine whether or not an attacker gains access to the
following functionality:
<FUNCTIONALITY-DESCRIPTION>
by exploiting this vulnerability:
<CVE-DESCRIPTION-a>
Examples of other CVEs that give an attacker access to
this functionality include:
<CVE-DESCRIPTION-i, ..., CVE-DESCRIPTION-k>
Examples of other CVEs that do not give an attacker
access to this functionality include:
<CVE-DESCRIPTION-m, ..., DESCRIPTION-n>
Answer with 'YES' or 'NO'.
```

C. Exploitation Technique

The top-level questions prompt is always used completely:

```
Did the user execute a malicious file?
...
Did the attacker 'sniff' unencrypted network traffic?
```

The follow-up questions depend on whether certain top-level questions had a positive answer (cf. CMM [3]):

```
Where did this file come from?
Answer with one of these alternatives:
[ "A malicious link", "An email", "A third-party service",
  "Removable media", "Other" ]
```

D. Affected Objects

```
An exploitation technique is the method (technique) used
to exploit the vulnerability. The types of objects that
are affected by an exploitation technique include
software, hardware, firmware, product, application, or
code. Your goal is to predict the affected object relevant
to the exploitation of the vulnerability. There should
only be one affected object. In the remainder, you will
first receive the vulnerability to label, then an
overview of affected objects to use as labels.
The vulnerability to be labeled has the following
description:
<CVE-DESCRIPTION>
The JSON string below describes the affected objects to
choose from:
[ {
  "affected_object": "Internet-facing Host/System",
  "description": "An Internet-facing host is any
    system that provides a doorway from the open
    Internet into your infrastructure.",
  "examples": ["webserver", "website", "database",
    "service"],
  "exploitation_technique": ["T1190", "T1211"]
}
  ...
]
Based on this information, what is the affected object?
Select one of the following:
[ "Internet-facing Host/System", ...,
  "External Remote Service" ]
```

E. Tactic

A tactic is the adversary's tactical goal: the reason for performing an action. For example, an adversary may want to achieve credential access. The task is to map from CVE to tactic.
Please map a CVE with the following description:
<CVE-DESCRIPTION>
to a tactic among the following tactics with corresponding descriptions:
<TACTIC-NAMES: TACTIC-DESCRIPTIONS>

F. In-Context Learner

The context variable includes:

You are a cybersecurity analyst specialized in applying MITRE's ATT&CK Framework to label vulnerability descriptions.

This prompt is repeated for each of the three mapping types:

An attack consists of three steps which corresponds to the following mapping types:

- Exploitation Technique - the method (technique) used to exploit the vulnerability
- Primary Impact - the initial benefit (impact) gained through exploitation of the vulnerability
- Secondary Impact - what the adversary can do by gaining the benefit of the primary impact

Given a vulnerability, your task is to determine the relevant attack techniques of type exploitation technique. You should output the top 10 most relevant attack techniques in descending order. An empty label indicating no relevant attack technique can be included among the top 10 where appropriate. In the remainder, you will first receive the vulnerability to label, then an overview of attack techniques to use as labels. Finally, you receive examples of correctly labeled vulnerabilities. The vulnerability to be labeled has the following description:

<CVE-DESCRIPTION>

The data in CSV format below describes the attack techniques to choose from:

```
-----
attack_id,attack_name
T1047,Windows Management Instrumentation
<...>
-----
```

The following CVE applies to this vulnerability:

<CVE-ID>: <CVE-DESCRIPTION>

The CVE has the following CVSS features:

```
-----
- cvssV2.accessVector: <CVSS-ACCESS-VECTOR>
  <...>
-----
```

The following is a JSON with examples. Each entry corresponds to a vulnerability which has a description and associated attack techniques by mapping type:

```
-----
{
  <CVE-ID>: {
    "description": <CVE_DESCRIPTION>,
    "attack_techniques":{
      "exploitation_technique": <TECHNIQUE_DETAILS>,
      "primary_impact": <TECHNIQUE_DETAILS>,
      "secondary_impact": <TECHNIQUE_DETAILS>
    }
  }
}
<...>
-----
```

Your task is to determine the relevant attack techniques of type <MAPPING-TYPE> for the given vulnerability. Provide a ranked list of either ten technique IDs or nine technique IDs and one 'None' value indicating the empty label. The 'None' value should be ranked similarly as the other techniques when applicable.

Here is an example of predicted output: ['T1068', None, 'T1168', 'T1290', 'T1078', 'T1180', 'T1010', 'T1435', 'T1320', 'T1100'].

The output should have the same format used in the example, and an extra explanation should not be included.